Penetration Test Report

Prepared By: Nishant Verma
Prepared For: Invoice Engine Web Application
Prepared On: June 7, 2024

Table of Contents

Section I

Application Penetration Test Report 3

1.0 Executive Summary 3

1.1 Project Overview 3

1.2 Objective and Scope 3

1.3 Assessment Team 3

1.4 Summary of Findings 4

1.5 Summary of the Test 4

2.0 Vulnerability Details 5

© 2024 NCR Voyix. All rights reserved. NCR Voyix – Confidential
Use and Disclose Solely Pursuant to Company Instructions

Application Penetration Test Report

1.0 Executive Summary

NCR AppSec team performed application penetration testing for Invoice Engine web application to find any security weaknesses in the application. This test was performed as of June 2024.

1.1 Project Overview

The AppSec team performed security testing of Invoice Engine web application to meet the annual security testing goal. The purpose of this test was to determine the security vulnerabilities in the application.

1.2 Objective and Scope

The objective of this assessment was to identify potential risks and for checking how effective the controls are in preventing any potential unauthorized information access. Following web application URLs and web services were provided to run the test.:

List of interfaces in-scope of the testing	
Test interface	https://ietest.ncrvoyix.com/ieweb/login3.jsp

Following test user profile was provided to access the web application.

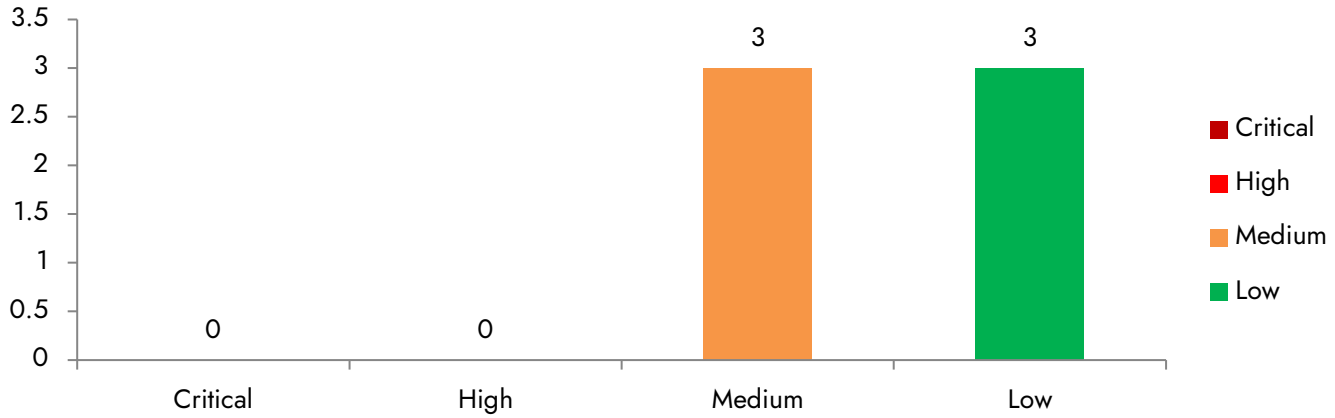
List of accounts provided for testing
LAN Credentials were used for the following QLIDs – - NV185055

1.3 Assessment Team

Name	Role
Nishant Verma	Information Security Engineer II

© 2024 NCR Voyix. All rights reserved. NCR Voyix – Confidential
Use and Disclose Solely Pursuant to Company Instructions

1.4 Summary of Findings



ID	Vulnerability	Risk Rating	Application/ System Impacted
1	Web server is vulnerable to Slowloris attack	Medium	ietest.ncrvoyix.com (153.74.154.53), ie.ncrvoyix.com (149.26.224.116)
2	SMB Misconfiguration	Medium	ietest.ncrvoyix.com (153.74.154.53)
3	Frameable Response – Potential Clickjacking	Medium	Invoice Engine web application
4	Security Headers misconfiguration	Low	Invoice Engine web application
5	Poor exception handling	Low	Invoice Engine web application
6	Apache Tomcat default page disclosure	Low	Invoice Engine web application

1.5 Summary of the Test

The assessment team performed an automated scanning and manual penetration testing of Invoice Engine web application. Following remediation is suggested to improve security of this application:

- Implement rate limiting and adjust timeout settings to restrict slow connections. Deploy a web application firewall (WAF) to detect and block slow HTTP attacks. Additionally, use load balancers to distribute traffic and mitigate the impact of the attack.
- Review and restrict permissions on the affected SMB shares to ensure only authorized users have access. Configure SMB shares to require proper authentication and segment the network to limit access to sensitive shares. Regularly audit permissions and configurations and implement monitoring to detect unauthorized access attempts.
- Implement X-Frame-Options or Content Security Policy (CSP) headers to prevent framing of your website. Regularly review and update these security headers to ensure protection against potential clickjacking attacks.

© 2024 NCR Voyix. All rights reserved. NCR Voyix – Confidential
Use and Disclose Solely Pursuant to Company Instructions

2.0 Vulnerability Details

ID	Vulnerability	Risk Rating	Application/ System Impacted
1	Web server is vulnerable to Slowloris attack	Medium	ietest.ncrvoyix.com (153.74.154.53), ie.ncrvoyix.com (149.26.224.116)

Vulnerability Description: The web server is vulnerable to a slow HTTP Denial of Service attack (DoS), otherwise referred to as the Slowloris HTTP attack. The attack exploits the fact that Apache waits for complete HTTP headers to be received before closing an HTTP connection. This means that an attacker can send multiple incompletes GET requests and keep the connections open to block other users from getting their requests processed by the server.

Evidence: Following image showing that server Is vulnerable to slowloris attack.

Dev: ietest.ncrvoyix.com (153.74.154.53)

```
Nmap scan report for susday13941.corp.ncr.com (153.74.154.53)
Host is up (0.0025s latency).
Not shown: 989 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
| http-slowloris-check:
|   VULNERABLE:
|   Slowloris DOS attack
|     State: LIKELY VULNERABLE
|     IDs:  CVE:CVE-2007-6750
|       Slowloris tries to keep many connections to the target web server open and hold
|       them open as long as possible.  It accomplishes this by opening connections to
|       the target web server and sending a partial request. By doing so, it starves
|       the http server's resources causing Denial Of Service.
|
|     Disclosure date: 2009-09-17
|     References:
|       https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
|_      http://ha.ckers.org/slowloris/
135/tcp   open  msrpc
```

Prod: ie.ncrvoyix.com (149.26.224.116)

```
Nmap scan report for susday15503.corp.ncr.com (149.26.224.116)
Host is up (0.00082s latency).
Not shown: 990 closed tcp ports (reset)
PORT      STATE SERVICE
80/tcp    open  http
| http-slowloris-check:
|   VULNERABLE:
|   Slowloris DOS attack
|     State: LIKELY VULNERABLE
|     IDs:  CVE:CVE-2007-6750
|       Slowloris tries to keep many connections to the target web server open and hold
|       them open as long as possible.  It accomplishes this by opening connections to
|       the target web server and sending a partial request. By doing so, it starves
|       the http server's resources causing Denial Of Service.
|
|     Disclosure date: 2009-09-17
|     References:
|       http://ha.ckers.org/slowloris/
|_      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
135/tcp   open  msrpc
```

© 2024 NCR Voyix. All rights reserved. NCR Voyix – Confidential
Use and Disclose Solely Pursuant to Company Instructions

Impact: Slowloris is an application layer DDoS attack which uses partial HTTP requests to open connections between a single computer and a targeted Web server, then keeping those connections open for as long as possible, thus overwhelming and slowing down the target. A malicious user can open many connections to the server by initiating HTTP requests but not closing them. If the attacker keeps every HTTP request open and feeds the server bogus data before the timeout is reached, the HTTP connection will remain open until the attacker closes it. Naturally, if an attacker occupies all available HTTP connections for a web server and keeps them busy waiting, legitimate connections cannot be processed by the server, and this causes a denial of service.
Recommendations: Upgrade the software to its latest version. Slowloris DDoS attacks can be mitigated by following the following steps: • Increase the maximum number of clients the Web server will allow. • Limit the number of connections a single IP address is allowed to attempt. • Place restrictions on the minimum transfer speed a connection is allowed. • Constrain the amount of time a client is permitted to stay connected.

© 2024 NCR Voyix. All rights reserved. NCR Voyix – Confidential
Use and Disclose Solely Pursuant to Company Instructions

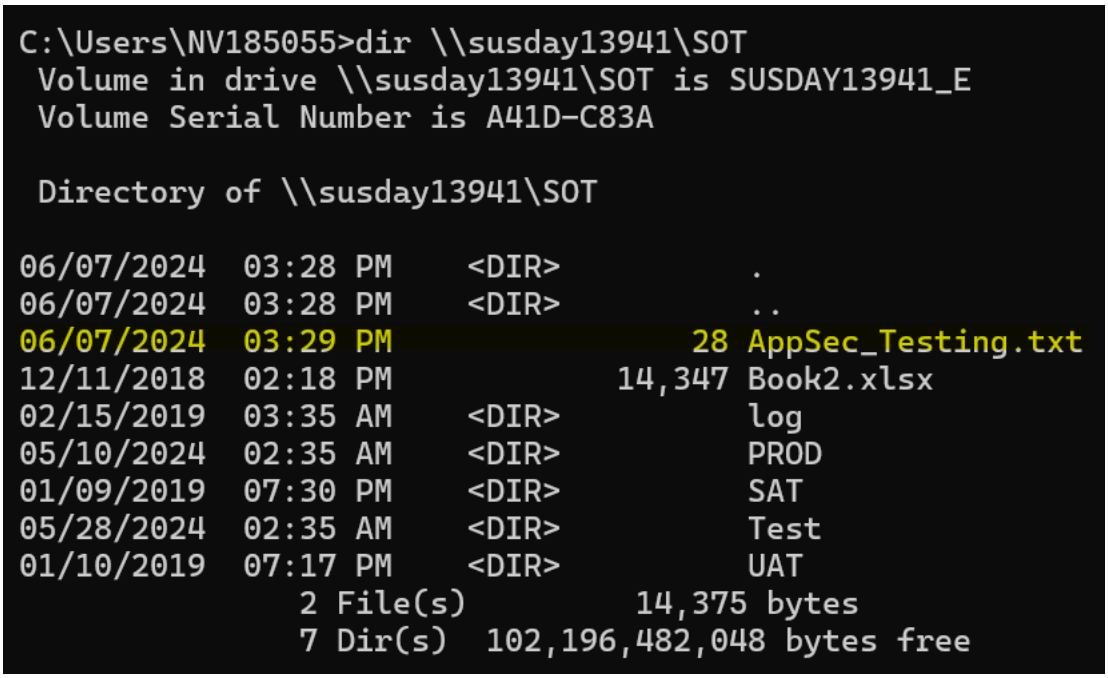
ID	Vulnerability	Risk Rating	Application/ System Impacted
2	SMB Misconfiguration	Medium	ietest.ncrvoyix.com (153.74.154.53)

Vulnerability Description: An SMB share on the NCR network has been identified with misconfigured permissions, allowing unauthorized read and write access. This vulnerability arises from improper access control settings on the SMB shares, which do not require proper authentication or authorization, enabling any network user to access, modify, or delete the files stored within these shares.

Evidence: It allows any individual within the network to gain unauthorized access to SMB directory, information disclosure, and other malicious activities. It poses a significant insider threat, as it grants any unauthorized user to access within NCR Network.

In the below screenshot, I created one text file with the name AppSec_Testing.txt.

Dev: \\ietest.ncrvoyix.com\SOT



Impact: The unsecured SMB directory vulnerability allows any individual within the company network to gain unauthorized access, leading to potential data breaches and the information disclosure. This can result in the compromise of sensitive files, financial loss, reputational damage, and the potential escalation of attacks on network resources.

Recommendation: Implementing strict access controls and authentication mechanisms, enabling encryption for SMB communications. Please refer following link for more details:

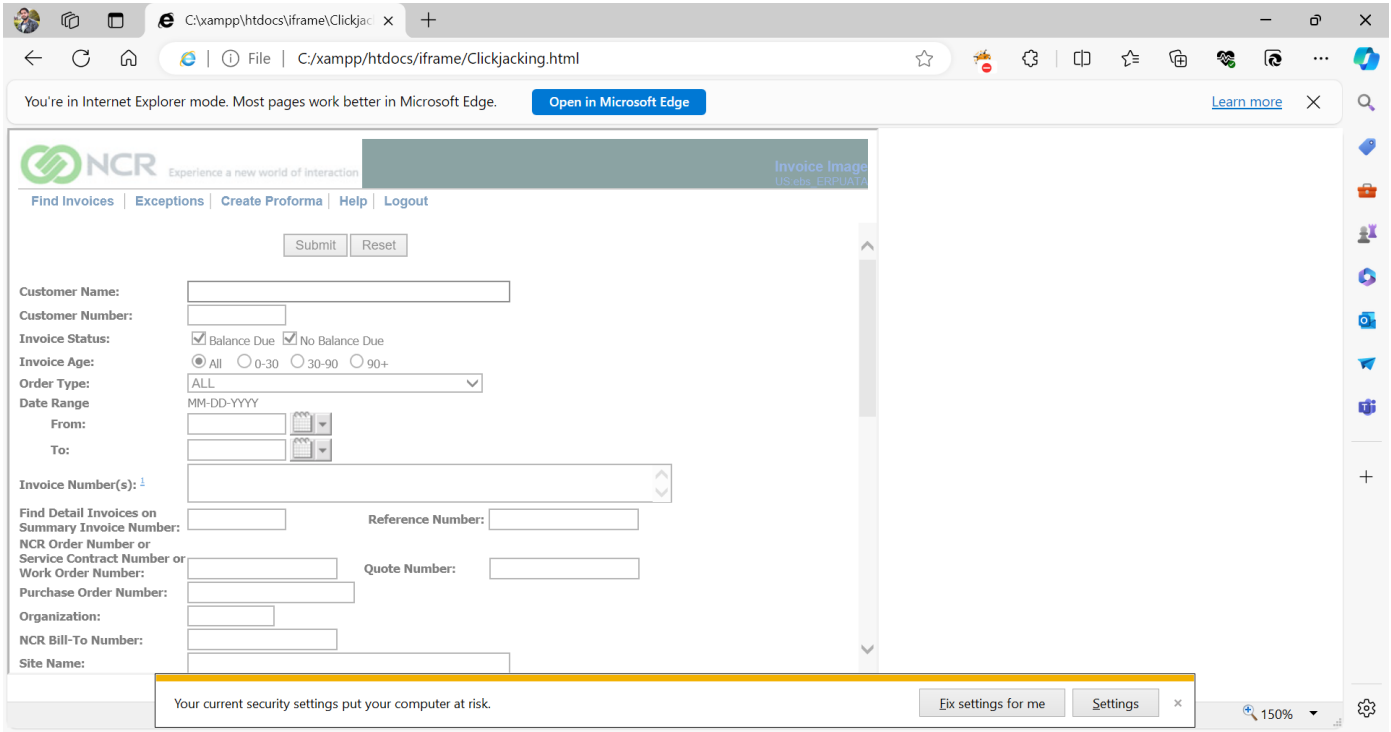
https://learn.microsoft.com/en-us/windows-server/storage/file-server/smb-security

© 2024 NCR Voyix. All rights reserved. NCR Voyix – Confidential
Use and Disclose Solely Pursuant to Company Instructions

ID	Vulnerability	Risk Rating	Application/ System Impacted
3	Frameable Response – Potential Clickjacking	Medium	Invoice Engine web application

Vulnerability Description: Cross-Frame Scripting (XFS) is an attack that combines malicious JavaScript with an iFrame that loads a legitimate page to steal data from an unsuspecting user. An attack example would consist of an attacker convincing the user to navigate to a web page the attacker controls. The attacker's page then loads malicious JavaScript and an HTML iFrame pointing to a legitimate site. Once the user enters credentials into the legitimate site within the iFrame, the malicious JavaScript steals the keystrokes.

Evidence: Testing shows that the whole application can be loaded into an iFrame.



Impact: This may enable a clickjacking attack, in which the attacker's page overlays the target application's interface with a different interface provided by the attacker. By inducing victim users to perform actions such as mouse clicks and keystrokes, the attacker can cause them to unwittingly carry out actions within the application that is being targeted.

Recommendations: Following is recommended to resolve this issue:

- Add a custom header in web.config file. Set X-Frame-Options Header Types, three possible values are:
- DENY: prevents any domain from framing the content. The "DENY" setting is recommended unless a specific need has been identified for framing.
- SAMEORIGIN: only allows the current site to frame the content.
- ALLOW-FROM uri: permits the specified 'uri' to frame this page. (e.g., ALLOW-FROM http://www.example.com)

```
<system.webServer>
  ...

  <httpProtocol>
    <customHeaders>
      <add name="X-Frame-Options" value="SAMEORIGIN" />
    </customHeaders>
  </httpProtocol>

  ...
</system.webServer>
```

© 2024 NCR Voyix. All rights reserved. NCR Voyix – Confidential
Use and Disclose Solely Pursuant to Company Instructions

ID	Vulnerability	Risk Rating	Application/ System Impacted
4	Security Headers misconfiguration	Low	Invoice Engine web application

Vulnerability Description: Security Headers are the directives to increase the protection and create more defense against vulnerabilities using browsers, adding a security header can prevent a variety of hacking attempts. However, a missing or misconfigured header can leave the web application vulnerable to attacks or give the attacker more information about the target.

Evidence: The assessment team found that following security headers are missing from the response of the web application:

- Clear-Site-Data - Clears browsing data (cookies, storage, cache) associated with the requesting website.
- Cross-Origin-Embedder-Policy - Prevents documents and workers from loading non-same-origin requests unless allowed.
- Cross-Origin-Opener-Policy - Prevent other websites from gaining arbitrary window references to a page.
- Cross-Origin-Resource-Policy - Protect servers against certain cross-origin or cross-site embedding of the returned source.
- Content-Security-Policy: Detect and mitigate Cross Site Scripting (XSS) and data injection attacks, among others.
- Permissions-Policy: Previously called "Feature-Policy", allow, and deny the use of browser features.

Recommendations: The assessment team recommends adding missing security headers.

Refer to the following links for more details:

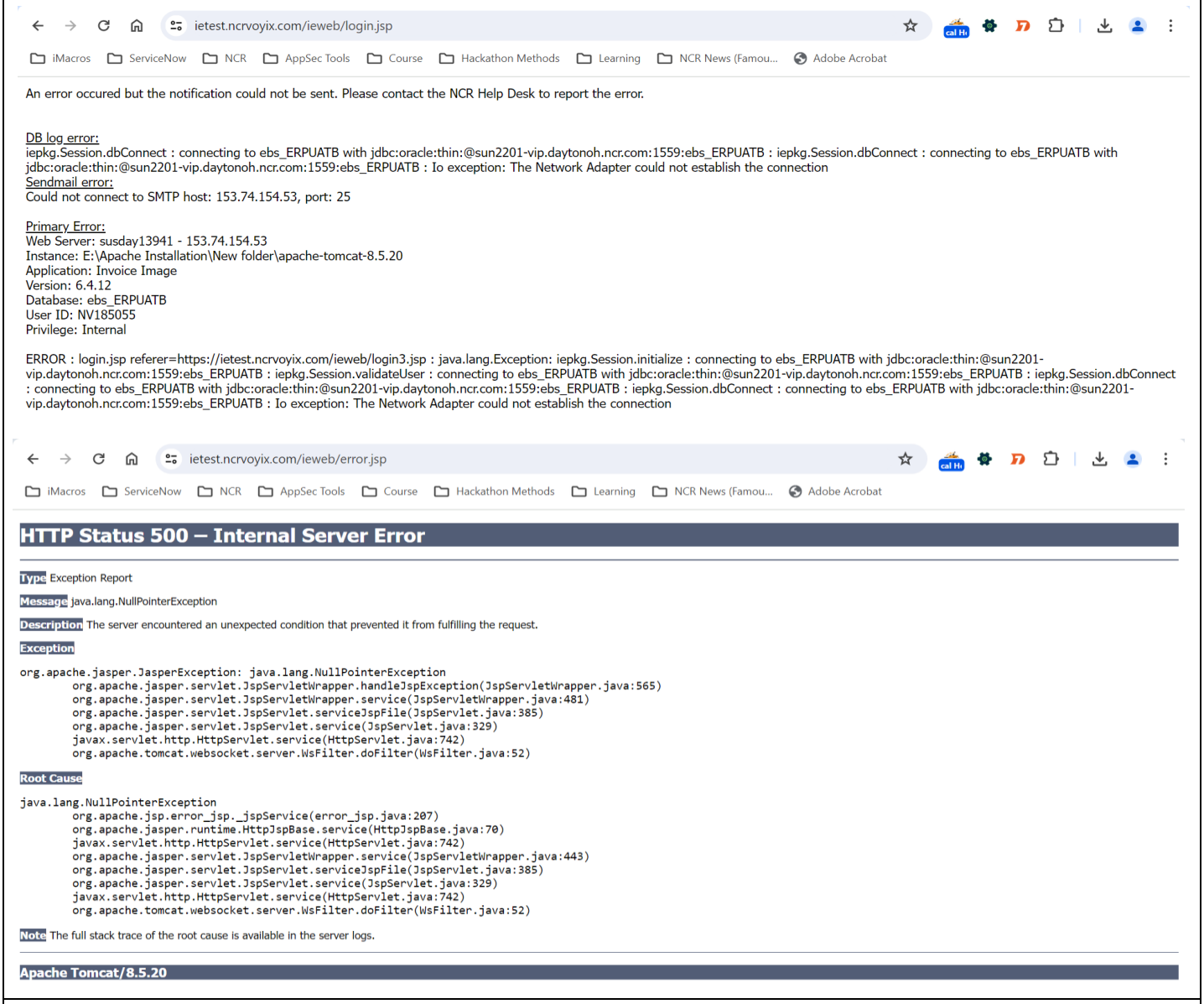
- https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Clear-Site-Data
- https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Cross-Origin-Embedder-Policy
- https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Cross-Origin-Opener-Policy
- https://developer.mozilla.org/en-US/docs/Web/HTTP/Cross-Origin_Resource_Policy_(CORP)
- https://content-security-policy.com/
- https://scotthelme.co.uk/goodbye-feature-policy-and-hello-permissions-policy/

© 2024 NCR Voyix. All rights reserved. NCR Voyix – Confidential
Use and Disclose Solely Pursuant to Company Instructions

ID	Vulnerability	Risk Rating	Application/ System Impacted
5	Poor exception handling	Low	Invoice Engine web application

Vulnerability Description: Improper handling of errors can introduce a variety of security problems for a website. The most common problem is when detailed internal error messages such as stack traces, database dumps, and error codes are displayed to the attacker. These messages reveal implementation details that should never be revealed. Such details can provide hackers important clues for potential flaws in the site and such messages are also disturbing to normal users.

Evidence: Unhandled exceptions occur when the application is not able to parse the user input properly in the form of exceptions and generate the error. Descriptive exception message will help an attacker to understand the way application is coded. An attacker can take advantage of it to exploit a section of code.



Impact: Attacker may understand system components and leaks in the system. Application may itself crash if exceptions are generated in a large number.

Recommendations: Implement a global error handler at the page or application level that catches all unhandled exceptions and routes them to a generic error page.

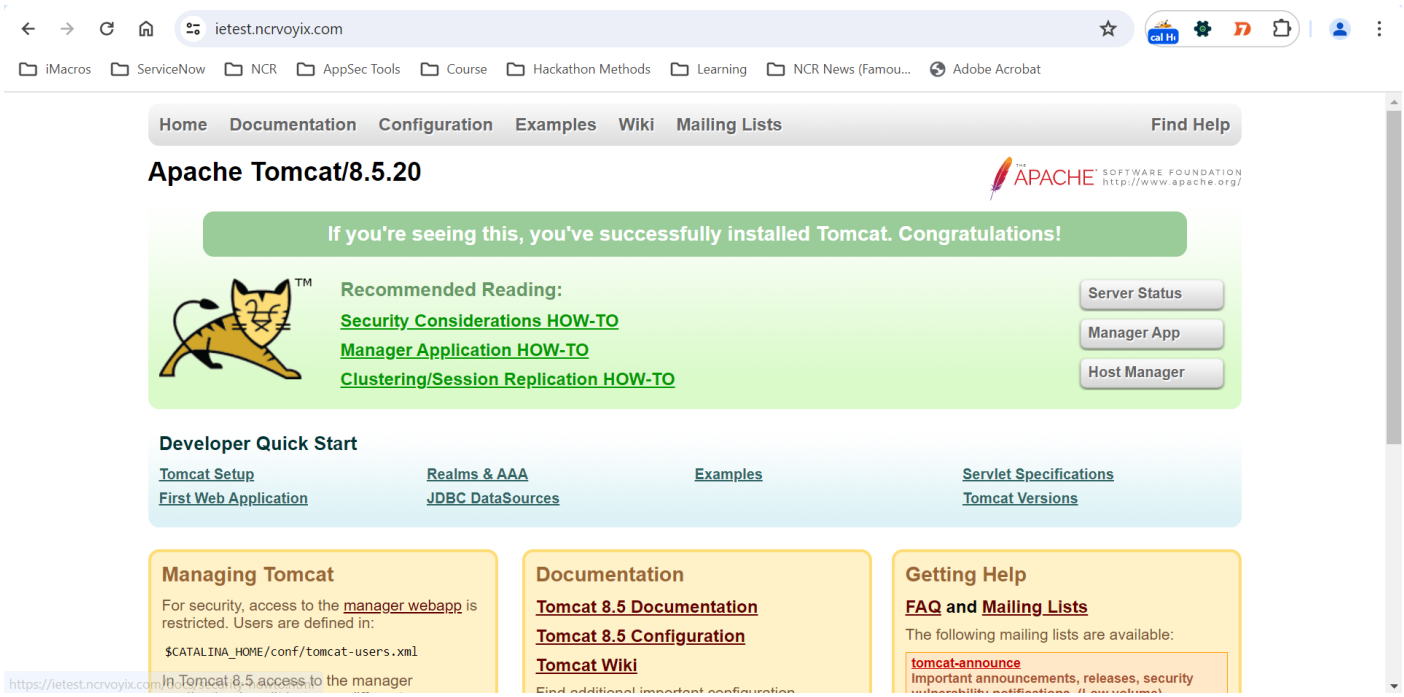
© 2024 NCR Voyix. All rights reserved. NCR Voyix – Confidential
Use and Disclose Solely Pursuant to Company Instructions

ID	Vulnerability	Risk Rating	Application/ System Impacted
6	Apache Tomcat default page disclosure	Low	Invoice Engine web application

Vulnerability Description: Default Tomcat page is accessible to anyone, potentially revealing sensitive information about the server and its configuration. Information disclosure, also known as information leakage, is when a website unintentionally reveals information that is sensitive or related to application architecture, using which the attackers can gain insights into the technology stack in use. This information can be used to identify known vulnerabilities.

Evidence: Apache Tomcat/8.5.20 is publicly accessible to all the users.

https://ietest.ncrvoyix.com/



Impact: Exposing Apache Tomcat default page publicly without proper security measures can expose significant risks.

Recommendations: Remove or disable default installation pages, example applications, and any other components that are not necessary for production use.

© 2024 NCR Voyix. All rights reserved. NCR Voyix – Confidential
Use and Disclose Solely Pursuant to Company Instructions